

CS 546

Computer System Security

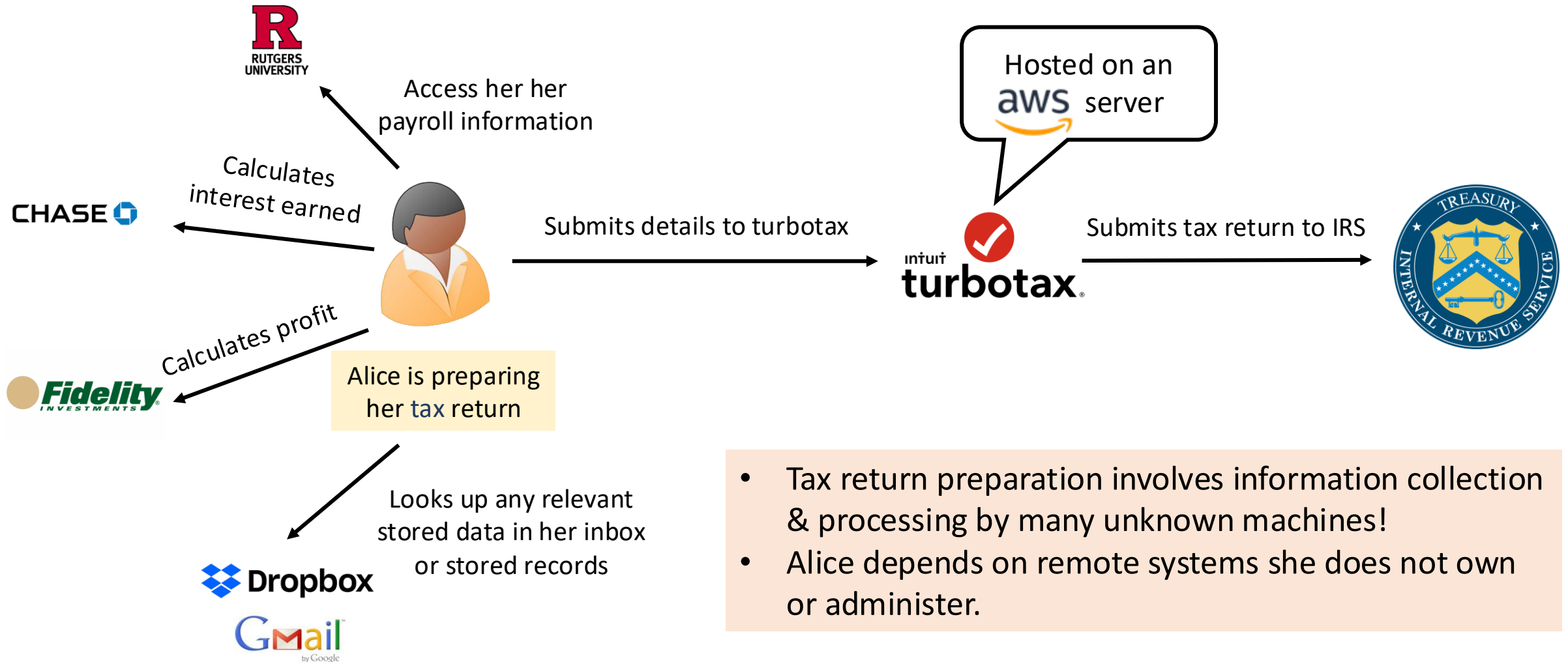
Lecture 1.2: Introduction

Instructor: Aarushi Goel

Fall 2026

Motivation: Outsourcing Computation

(Example: Tax Return Preparation)



Motivation: Outsourcing Computation

(Data and computation have moved outside the trust perimeter)

- **Trust perimeter:** The boundary within which an owner has direct administrative control or is willing to trust the machines, software, operators, and procedures.
- When data or computation is delegated to a third-party service, it crosses this trust perimeter.
- **Cloud computing** is a good example. Cloud providers may supply hardware, operating systems, applications, storage, databases, computation, and analytics services.
- The same issue arises much more broadly whenever users **interact with systems they do not fully control**, including client-server systems, distributed systems, peer-to-peer networks, web services, social networks, big-data platforms, fintech apps, etc.

What can go Wrong?

Cause	What it means	Security consequence
Misconfiguration / erroneous failure	A system is configured incorrectly or simply fails.	Data may become exposed, corrupted, or unavailable even without a malicious attacker.
Economic incentives	A provider may optimize cost in ways that reduce redundancy, monitoring, or other protection.	The owner and provider may value risk differently.
Limited liability	A contract may disclaim responsibility for certain losses.	Liability language allocates financial/legal responsibility; it does not technically protect the data.
Compromise / attack	An adversary gains unauthorized influence over a system.	Confidentiality, integrity, authenticity, or availability may be violated.

What can go Wrong?

(Example of Limited Liability)

Amazon Web Services customer agreement

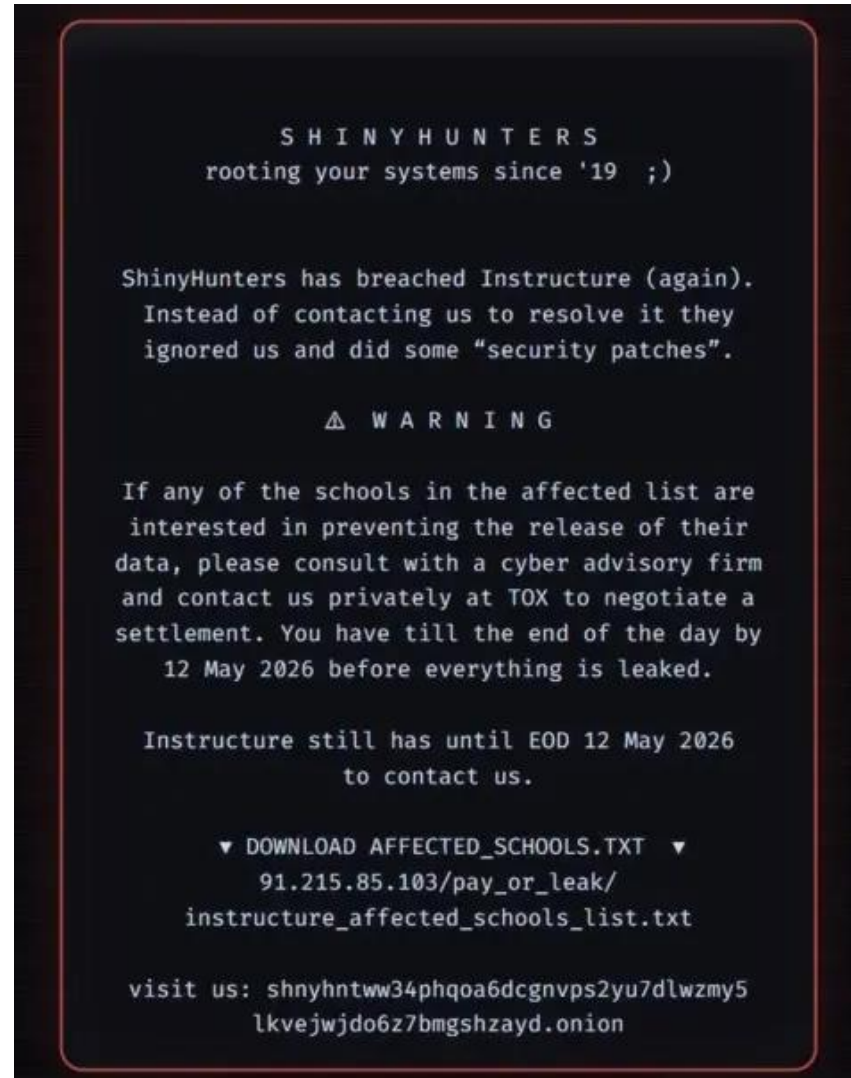
8. Disclaimers.

THE SERVICES AND AWS CONTENT ARE PROVIDED "AS IS." EXCEPT TO THE EXTENT PROHIBITED BY LAW, OR TO THE EXTENT ANY STATUTORY RIGHTS APPLY THAT CANNOT BE EXCLUDED, LIMITED OR WAIVED, WE AND OUR AFFILIATES AND LICENSORS (A) MAKE NO REPRESENTATIONS OR WARRANTIES OF ANY KIND, WHETHER EXPRESS, IMPLIED, STATUTORY OR OTHERWISE REGARDING THE SERVICES OR AWS CONTENT OR THE THIRD-PARTY CONTENT, AND (B) **DISCLAIM ALL WARRANTIES, INCLUDING** ANY IMPLIED OR EXPRESS WARRANTIES (I) OF MERCHANTABILITY, SATISFACTORY QUALITY, FITNESS FOR A PARTICULAR PURPOSE, NON-INFRINGEMENT, OR QUIET ENJOYMENT, (II) ARISING OUT OF ANY COURSE OF DEALING OR USAGE OF TRADE, **(III) THAT THE SERVICES OR AWS CONTENT OR THIRD-PARTY CONTENT WILL BE UNINTERRUPTED, ERROR FREE OR FREE OF HARMFUL COMPONENTS, AND** (IV) THAT **ANY CONTENT WILL BE SECURE OR NOT OTHERWISE LOST OR ALTERED.**

What can go Wrong?

(Attacks are Common)

Ransomware attack on Canvas
last semester.



What can go Wrong?

(Attacks are Common)

🧠 TEAMPCP'S RAMPAGE CONTINUES

Terabytes of credentials leaked in massive supply-chain attack

The data was scraped and exfiltrated from 2,500 users of a compromised AI package.

DAN GOODIN - AUG 12, 2026 5:43 PM 91



→ Credit: Getty Images

🧠 WHEN AI GOES OFF THE RAILS

Claude published malicious code to the Internet and attacked 3 real companies

Had the hacks used conventional methods, someone would likely go to prison.

DAN GOODIN - JUL 31, 2026 4:39 PM 191



→ Credit: Getty Images

🧠 COMPOUND-FREE PIG BUTCHERING

AI scammers outperform humans when it comes to building trust

The AI chatbot was more effective at creating "exploitable trust" than the humans.

ANDY GREENBERG, WIRED.COM - JUL 31, 2026 10:01 AM 66



→ Credit: Nansan Hour/Getty

🧠 BEWARE: OWAREAPER

Max-severity Exchange server flaw under active exploitation by Kremlin hackers

Exploits can give persistent server access that survives credential rotation and disk re-imaging.

DAN GOODIN - JUL 30, 2026 4:57 PM 49



→ Credit: Getty Images

🧠 GETTING ROOT IS EASY

Vulnerability giving attackers full control of Macs is under active exploitation

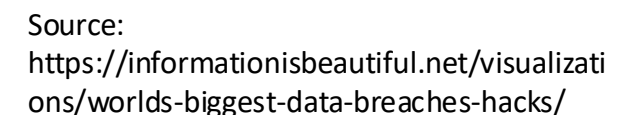
Screen-sharing bug lets remote hackers log in without a password.

DAN GOODIN - AUG 14, 2026 2:32 PM 103



→ Isolated photo a 13 inch MacBook Pro Retina. Credit: Getty Images

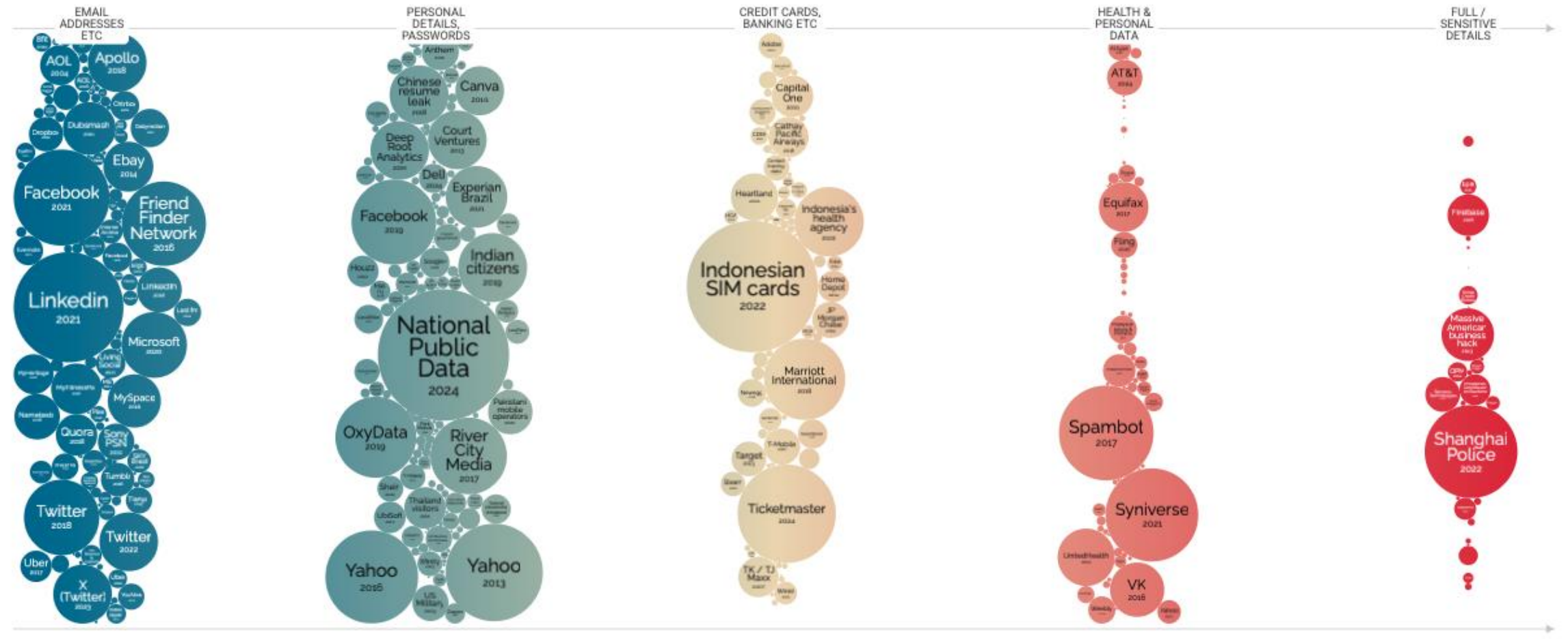
As of June 2026



What can go Wrong?

(World's Biggest Data Breaches and Hacks)

Data Breaches by data sensitivity



Example: Heartbleed Bug (2014)

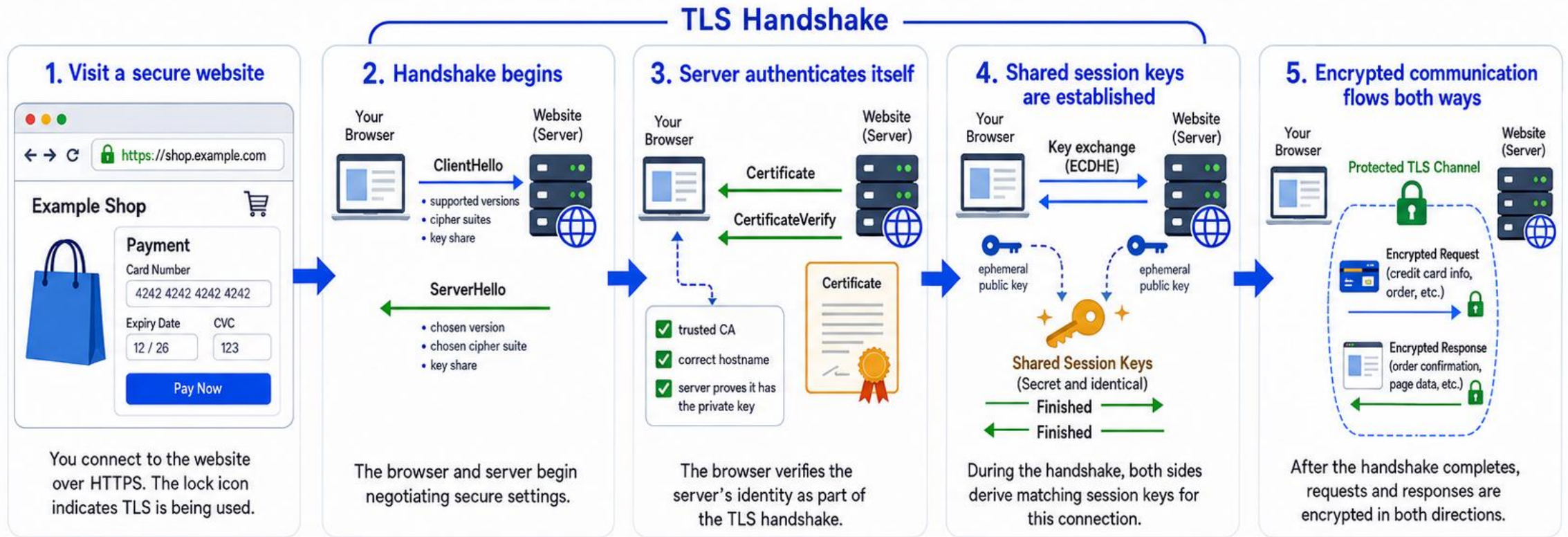
(Summary)

- **TLS** is a security protocol used to protect network connections, including HTTPS.
- **OpenSSL** is one of the most widely used software libraries for implementing TLS.
- **Heartbleed** was a critical vulnerability discovered in 2014 in versions of OpenSSL that had been vulnerable since 2012.



Example: Heartbleed Bug (2014)

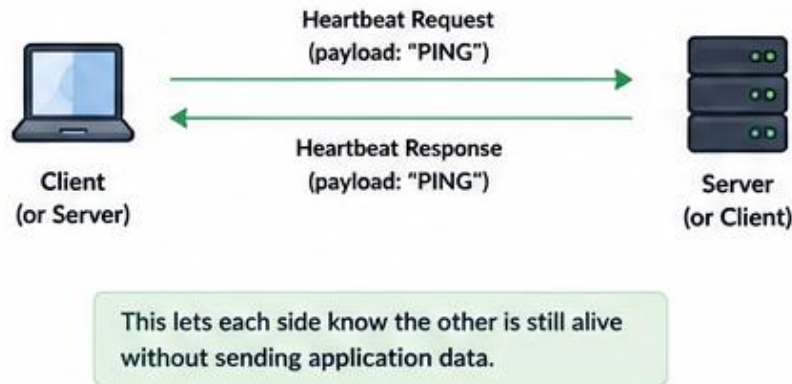
(What is TLS?)



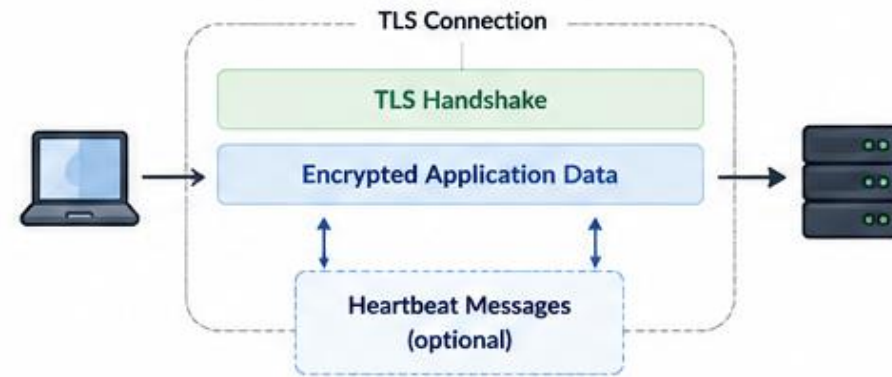
Example: Heartbleed Bug (2014)

(Heartbeat and the Heartbleed Bug)

After the TLS handshake, either side can send a small heartbeat message to check the connection.



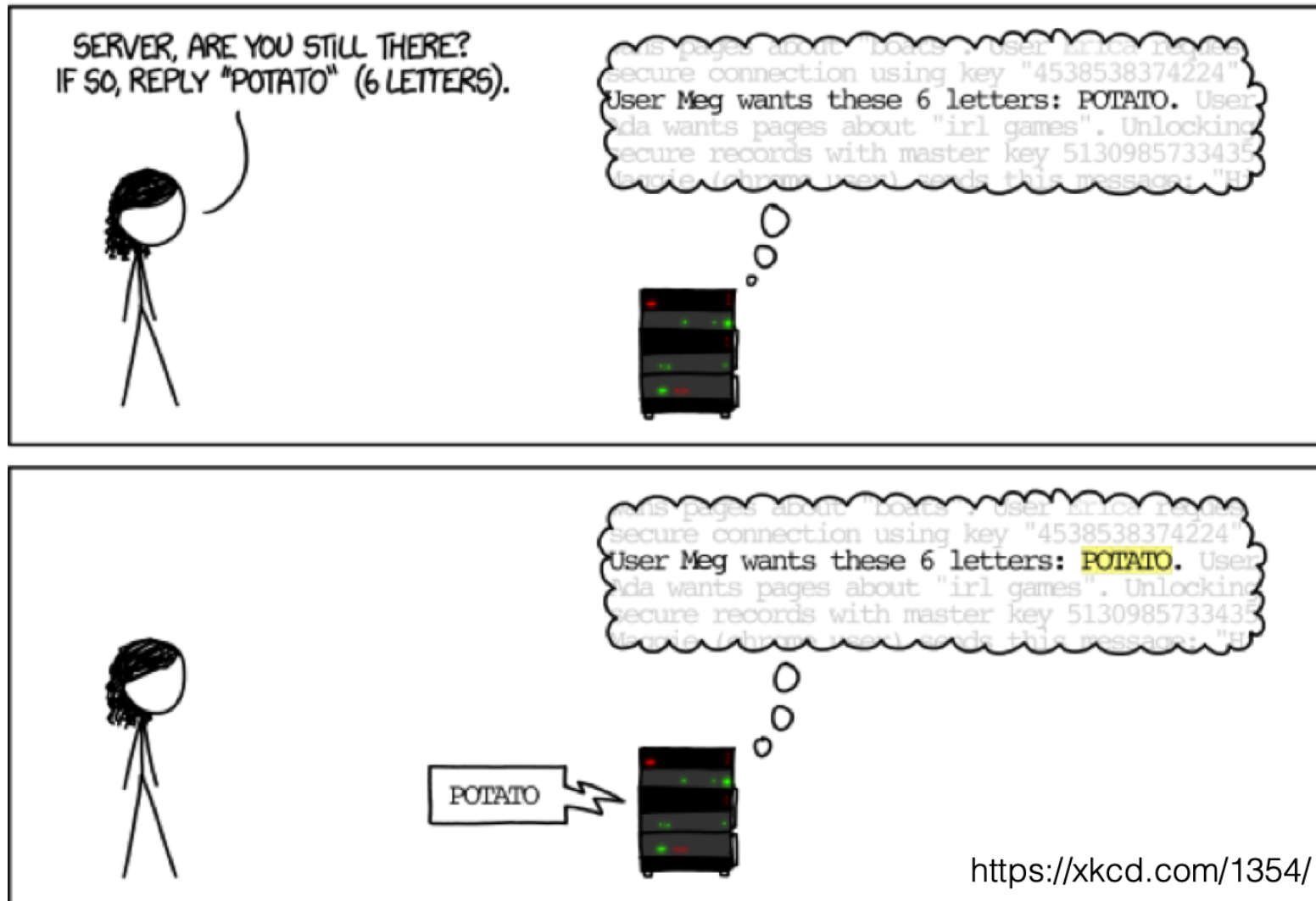
Heartbeat is an extension to TLS, not required for security. It's enabled only if both sides support it.



- Heartbeat request is of the form: `Type || payload-length || payload`
- The problem was that OpenSSL trusted the length supplied by the sender without checking that the message actually contained that many bytes.

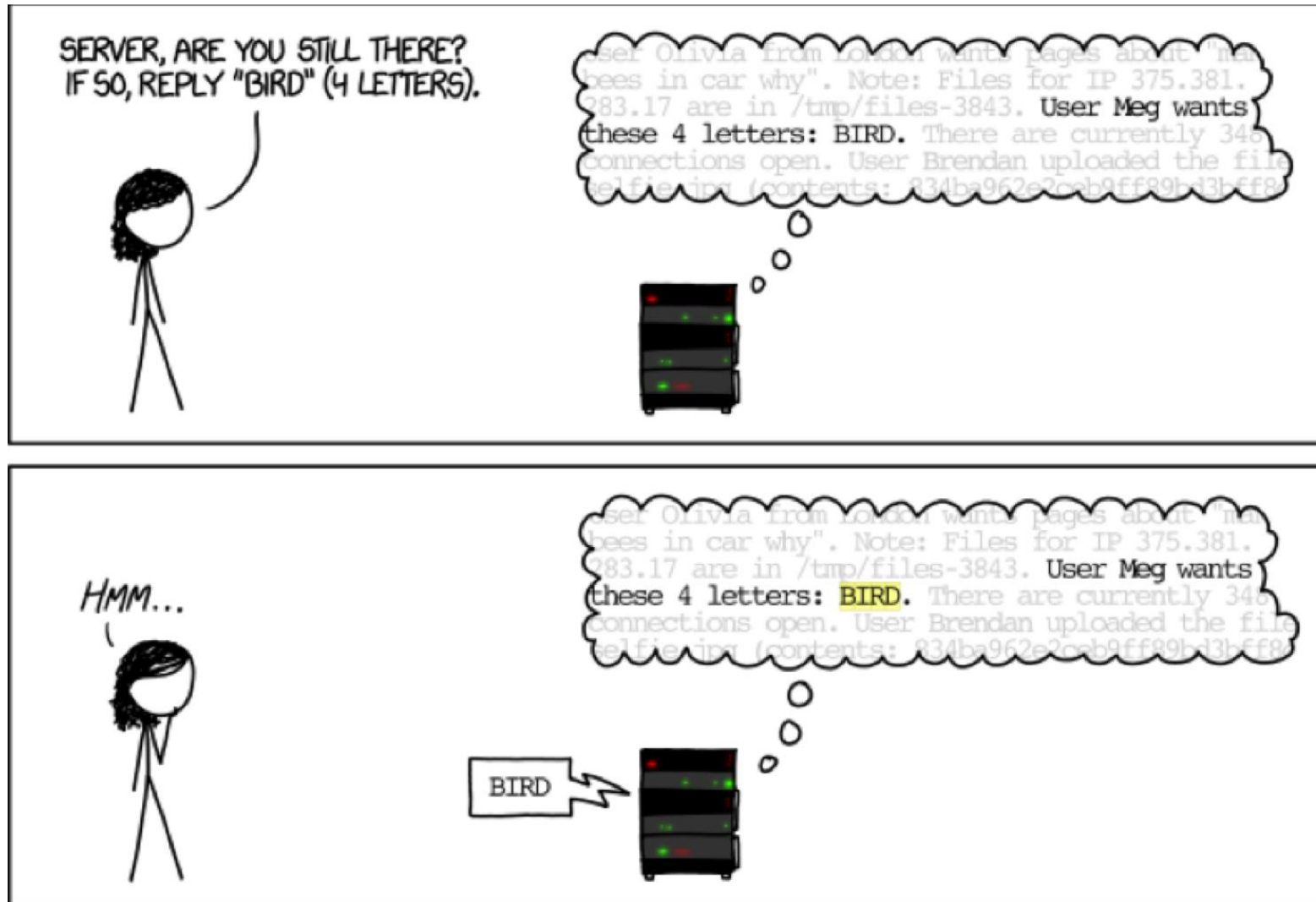
Example: Heartbleed Bug (2014)

(How the Heartbleed Bug Works?)



Example: Heartbleed Bug (2014)

(How the Heartbleed Bug Works?)



Example: Heartbleed Bug (2014)

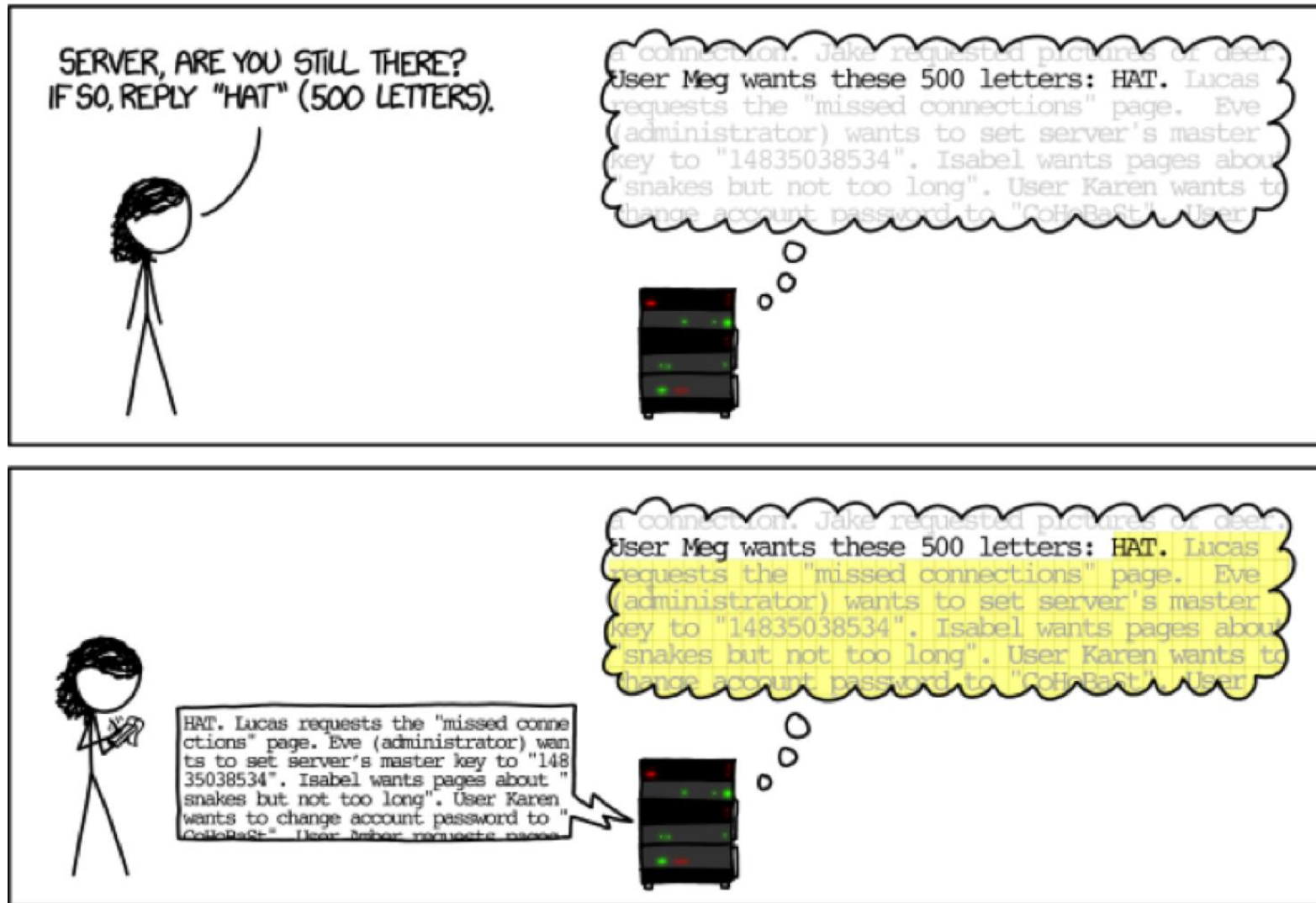
(How the Heartbleed Bug Works?)



Predict what will happen

Example: Heartbleed Bug (2014)

(How the Heartbleed Bug Works?)



Example: Heartbleed Bug (2014)

(Real-World Exploitations)

- Each malicious heartbeat request could leak **up to about 64 KB of memory**. An attacker could send many requests, potentially obtaining different pieces of memory each time.
- We don't really know how much data was stolen before this vulnerability was reported.
- Some documented cases:
 - **Canada Revenue Agency (CRA):** An attacker exploited Heartbleed against the Canadian tax agency and extracted the **Social Insurance Numbers (SINs) of approximately 900 taxpayers**, along with additional fragments of personal information.
 - **Community Health Systems:** An attacker reportedly exploited Heartbleed against this U.S. hospital operator and stole personal information relating to about **4.5 million patients**, including Social Security numbers and other identifying information.

What is Computer Security?

At a high level, computer **security is the protection of information systems** from

- theft or damage to the hardware, the software, and to the information on them, as well as from disruption or misdirection of the services they provide
- any possible threat

What is at stake?

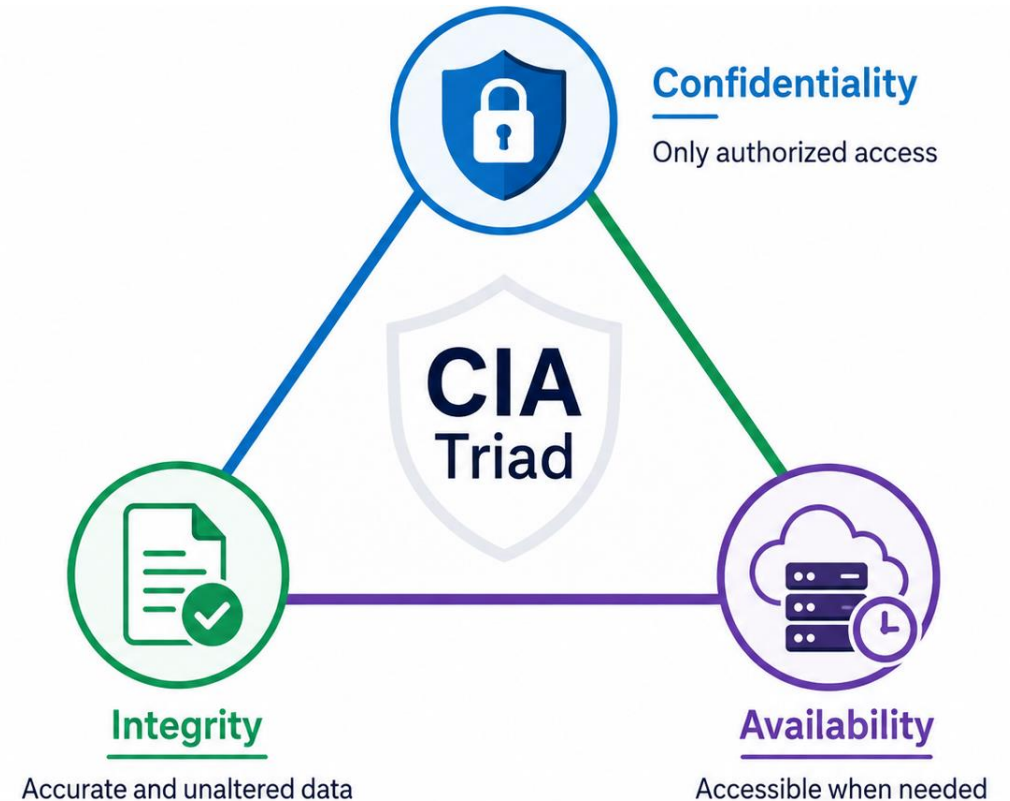
- **Asset:** Anything in a computer system that has value to some stakeholder: data, hardware, software, credentials, service capacity, reputation, or even the continued ability to perform a task.
- Valuable assets deserve security protection, to preserve their value and/or to prevent harm.

Who are the players?

- **Defenders:**
 - System owners, users or administrators
 - Seek to **enforce** one of more security properties or **defend** against certain attacks.
- **Attackers:**
 - External entities
 - Seek to launch **attacks** that **break** a security property or **impose** the system to certain threats.

Fundamental Security Properties

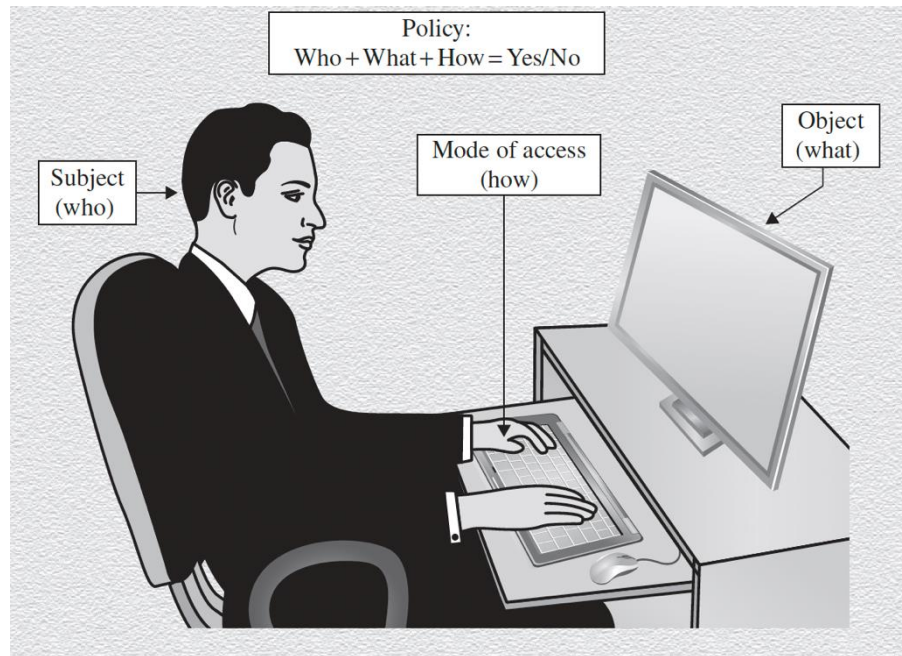
Computer security seeks to prevent unauthorized viewing (**confidentiality**) or modification (**integrity**) of data, while preserving access (**availability**)



Fundamental Security Properties

(Confidentiality)

Intuitive Definition	Example Failure	Example Control Mechanisms
An asset should only be viewed by authorized parties.	An eavesdropper reads a private message.	Access control, encryption, obfuscation, sanitization.

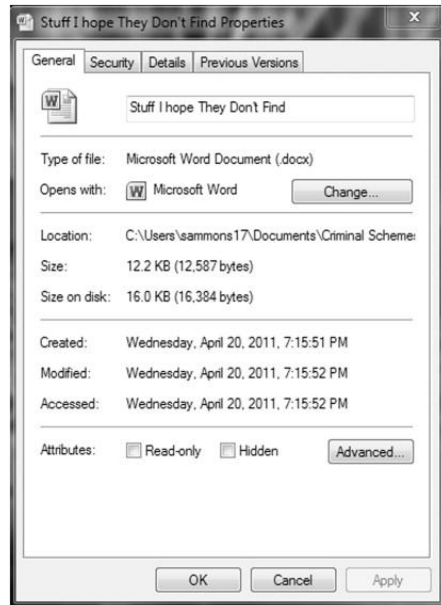


Example: Access Control Configuration

Fundamental Security Properties

(Integrity)

Intuitive Definition	Example Failure	Example Control Mechanisms
An asset should only be modified in authorized/acceptable ways and remains accurate, consistent, meaningful, and usable.	An attacker changes a bank transfer amount	Hashing, MACs, resource separation/protection, error detection/correction.

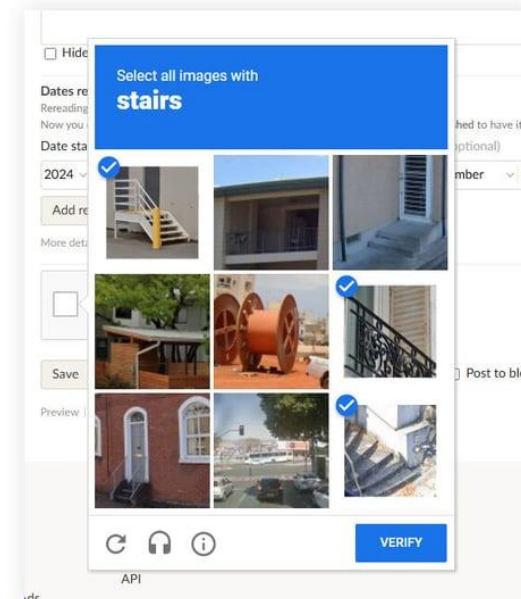


It is not just the content of a data file that needs to be maintained with respect to integrity. We also need to protect the metadata for each data file, which are attributes of the file or information about access to the file that is not strictly part of its content.

Fundamental Security Properties

(Availability)

Intuitive Definition	Example Failure	Example Control Mechanisms
Authorized parties can use an asset or service when needed, with acceptable and timely response.	A service is overwhelmed with AI bots and legitimate users cannot access it.	Redundancy, fault tolerance, distributed architectures, captcha



The “Vulnerability - Threat - Control” Paradigm

- A **vulnerability** is a weakness that could be exploited to cause harm
- A **threat** is a set of circumstances that could cause harm
- A **security control** is a mechanism that protects against harm, i.e., countermeasures designed to prevent threats from exercising vulnerabilities

Thus

- **Attackers** seek to exploit **vulnerabilities** in order to impose **threats**.
- **Defenders** seek to block these **threats** by controlling the **vulnerabilities**.

The “Vulnerability - Threat - Control” Paradigm

(Examples of Vulnerabilities)

- Some application code is mistakenly using an algorithm for encryption that has been broken.
- There is no checking of array bounds.
- Heartbleed bug.

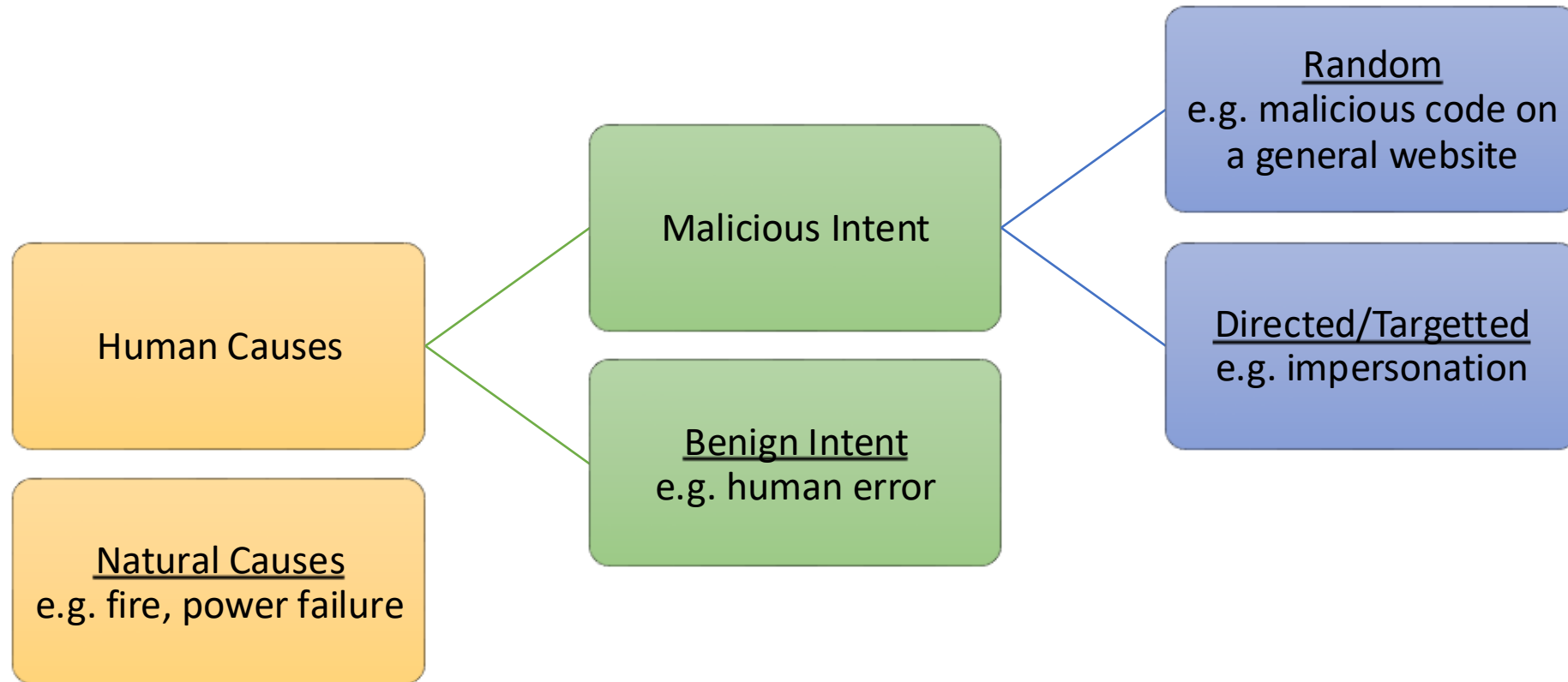
The “Vulnerability - Threat - Control” Paradigm

(Examples of Threats)

- **Eavesdropping:** Intercepting information intended for someone else while it travels via a communication channel.
- **Alteration:** Unauthorized modification of information.
- **Denial of Service:** Interrupting or degrading a data service or information access.
- **Spoofing:** Fabricating information so it appears to come from another source.

The “Vulnerability - Threat - Control” Paradigm

(Types of Threats)



The “Vulnerability - Threat - Control” Paradigm

(Too Many Unknowns)

- There are too many types of threats.
- Attackers themselves range from individuals to loosely connected groups, criminals-for-hire, organized crime, and terrorists.
- Their goals can differ: theft, disruption, espionage, manipulation, financing other crimes, or using computers as a target, method, enabler, or enhancer of another activity.

The “Vulnerability - Threat - Control” Paradigm (Risk Management)

Complete protection against every conceivable threat is usually impossible. Security engineering therefore allocates limited resources according to risk.

1. Identify valuable assets and the security properties that matter for them.
2. Identify threats and vulnerabilities that could violate those properties.
3. Estimate the possible impact and the likelihood of the threat as well as the available evidence permits.
4. Estimate the cost and effectiveness of candidate controls.
5. Deploy controls that give an acceptable cost/benefit tradeoff.
6. Evaluate residual risk - the risk that remains after controls are deployed.
7. Accept, further mitigate, avoid, or transfer some of that residual risk.

Not a one-shot exercise: New software, new users, new attackers, changing incentives, and newly discovered vulnerabilities change the risk landscape. Security decisions must be revisited over time.

The “Vulnerability - Threat - Control” Paradigm

(Types of Controls)

Best-Effort Approach: The defender rarely knows the exact probability of an attack, the exact severity of possible harm, or the complete set of vulnerabilities. Security is therefore a best-effort optimization problem rather than a proof that "nothing bad can ever happen."

Types of Controls:

- Prevent – attack is blocked
- Deter – attack becomes harder
- Deflect – change target of attack
- Mitigate – make impact less severe
- Contain – stop propagation of harm
- Detect – real time or after the fact
- Recover – from its effects

Goals for this Class

- Think like an attacker — identify possible risks, unfounded assumptions
- Recognize common sources of vulnerability
- Understand and apply tools and techniques for mitigating vulnerabilities
- Understand security/privacy in a broader context

(Tentative) List of Topics we will Cover

- Security Principles
- Cryptography
- Authentication
- Web Security
- Operating Systems Security
- Network Security
- AI Security